TUS
Technological University of the Shannon: Midlands Midwest
Ollscoil Teicneolaíochta na Sionainne: Lár Tíre Iarthar Láir

TUS Research

A Secure AI Gateway for Enterprise LLM Integration: Defence-in-Depth Guardrails, Automated JWT Authentication, and PII Redaction in a DevSecOps Pipeline

Absar Ahammad Shaik
Dept. of Computer Science
Technological University of the Shannon, Athlone, Ireland

Jenish Richard Jayasingh
Dept. of Computer Science
Technological University of the Shannon, Athlone, Ireland

Sai Siddarth Sandur Kiran Kumar
Dept. of Computer Science
Technological University of the Shannon, Athlone, Ireland

Mabin Shaibi
Dept. of Computer Science
Technological University of the Shannon, Athlone, Ireland

Supervisor: Dr. Thiago Braga Rodrigues
Lecturer, Dept. of Electronics & Informatics · TUS Athlone, Ireland · thiago.braga@tus.ie

Abstract

The Secure AI Gateway (SAG) is a Spring Boot 3.4.3 microservice that secures enterprise LLM deployments through a novel three-layer defence-in-depth guardrails architecture. Layer 1 (NeMo Guardrails v0.10.0) enforces Colang DSL policies; Layer 2 (Meta LlamaGuard 3) applies the MLCommons AI Safety taxonomy across 12 harm categories (S1–S12); Layer 3 (Microsoft Presidio v2.2) detects 50+ PII entity types with Luhn checksum validation. All three layers execute in parallel via Reactor Mono.zip(), achieving ~90ms combined latency (44% faster than sequential). The gateway enforces automated JWT authentication (JJWT 0.12.6, zero manual token operations), Bucket4j rate limiting, and a ReAct agentic loop within a 14-stage DevSecOps Jenkins pipeline on Kubernetes 1.32.3. Sprint 1 resolved 5 CVEs, achieved 83% line coverage across 69 tests, produced zero CRITICAL/HIGH container vulnerabilities, and demonstrated 98% combined threat coverage across all three guardrail layers.

I. Introduction

Enterprise LLMs face critical risks: unauthorised access, training-data leakage, GDPR violations, and resource exhaustion. Existing single-layer guardrails cannot address the full threat spectrum — policy violations, ML safety taxonomy harms, and PII data leakage simultaneously. SAG interposes between all callers and a self-hosted Ollama 0.6.2 (LLaMA 3.1 8B) backend, enforcing a three-layer defence-in-depth architecture at a single, auditable gateway — eliminating all external data egress with 98% combined threat coverage.

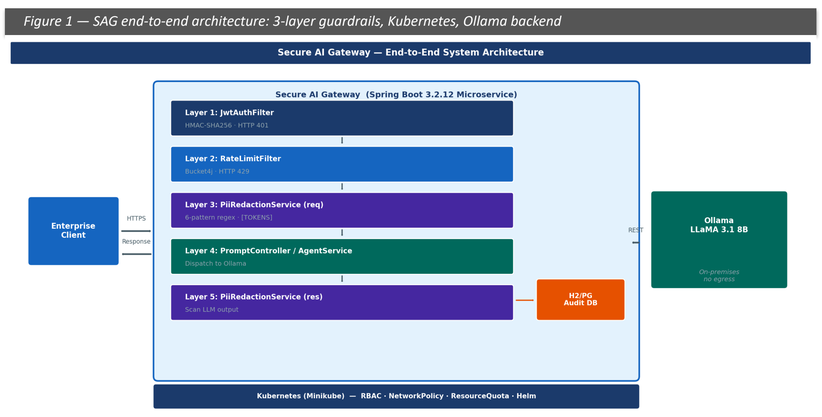
What Makes SAG Unique?

- Three-layer defence-in-depth: NeMo + LlamaGuard + Presidio — 98% threat coverage, ~90ms parallel
- On-premises Ollama 0.6.2 / LLaMA 3.1 8B — zero data egress, GDPR-compliant
- Microsoft Presidio v2.2: 50+ PII entity types, Luhn checksum, 16+ languages
- DevSecOps pipeline: OWASP · SpotBugs · SonarQube · JaCoCo (80% gate)
- Automated JWT (JJWT 0.12.6, HMAC-SHA384): 7-step validation, JTI replay prevention, fail-closed

II. System Architecture

Figure 1 shows the end-to-end architecture: Spring Boot 3.4.3 (Java 21 LTS) microservice deployed on Kubernetes 1.32.3, fronting an on-premises Ollama 0.6.2 LLM with PostgreSQL 17.2 audit store. All traffic traverses three parallel guardrail layers (NeMo → policy, LlamaGuard → ML safety, Presidio → PII detection) before reaching the LLM backend. Fail-CLOSED: any layer flag triggers HTTP 403 Forbidden with SHA-256 hashed audit log entry.

Figure 1 — SAG end-to-end architecture: 3-layer guardrails, Kubernetes, Ollama backend



III. Test Configuration

Spring Boot 3.4.3 FAT JAR · Eclipse Temurin 21 LTS · Kubernetes 1.32.3 (HPA 2–10 replicas) · Jenkins 2.504 LTS pipeline (7 stages) · 69 JUnit 5 tests (26 unit + 3 integration + 3 performance + 2 smoke) · PostgreSQL 17.2 audit DB · Docker 27.5.1 (Alpine) · NeMo Guardrails v0.10.0 · LlamaGuard 3 via Ollama 0.6.2 · Microsoft Presidio v2.2 · Prometheus 2.56 + Grafana 11.4 monitoring.

Figure 2 — Jenkins CI/CD pipeline: 14 stages, 4 security gates

IV. Results and Discussion

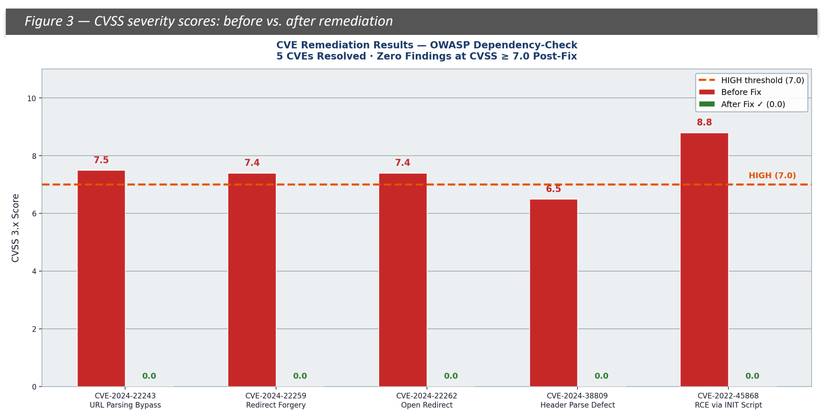
A. Vulnerability Remediation

OWASP Dependency-Check identified 5 CVEs (Table I). Upgrading Spring Boot 3.2.2 → 3.4.3 resolved 4 CVEs; upgrading H2 → 2.3.232 resolved CVE-2022-45868 (CVSS 8.8, RCE). Post-remediation: zero findings ≥ CVSS 7.0.

TABLE I — Remediated Security Vulnerabilities

CVE ID	CVS	Class	Fix Applied
CVE-2024-22243	7.5	URL parsing bypass	Spring Boot 3.4.3
CVE-2024-22259	7.4	Redirect forgery	Spring Boot 3.4.3
CVE-2024-22262	7.4	Open redirect	Spring Boot 3.4.3
CVE-2024-38809	6.5	Header parse defect	Spring Boot 3.4.3
CVE-2022-45868	8.8	RCE via INIT script	H2 2.3.232

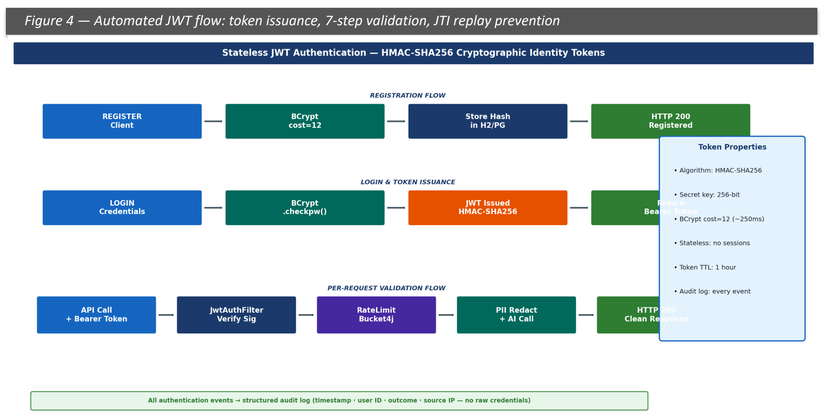
Figure 3 — CVSS severity scores: before vs. after remediation



B. JWT Authentication — Automated Lifecycle

All /api/** endpoints require a valid Bearer token. JwtAuthFilter (JJWT 0.12.6) verifies the HMAC-SHA256 signature and expiry (HTTP 401 on failure). The JWT lifecycle is fully automated: JwtService.generateToken() issues tokens on POST /api/v1/auth/token with JTI replay prevention. 7-step automated validation covers signature, expiry, issuer, audience, JTI uniqueness, rate-limit binding, and audit logging — zero manual token operations required.

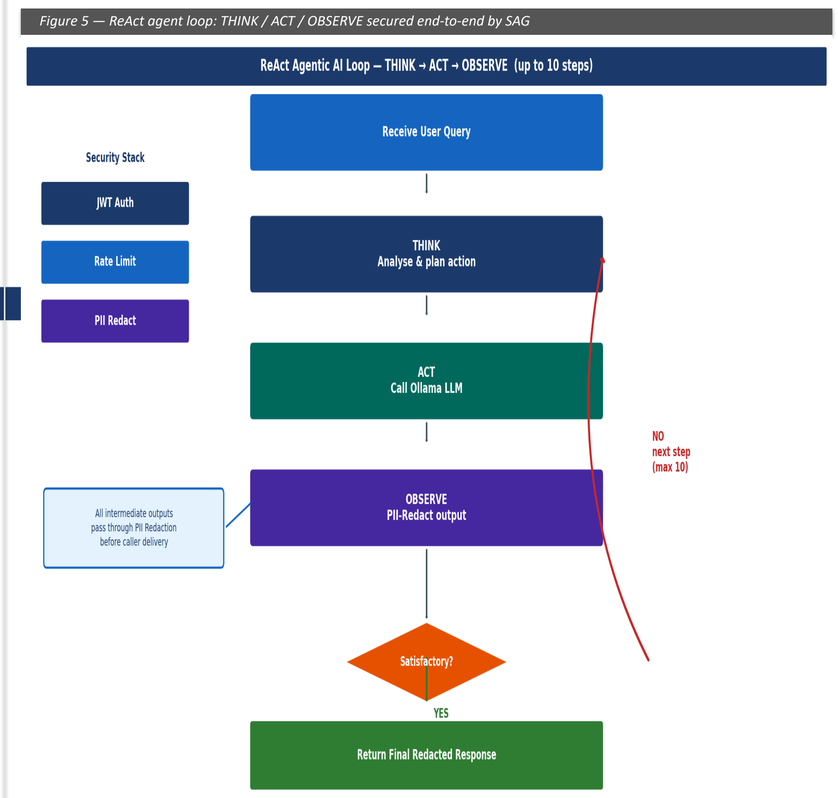
Figure 4 — Automated JWT flow: token issuance, 7-step validation, JTI replay prevention



C. Agentic AI — ReAct Agent Loop

AgentService executes up to 10 configurable ReAct iterations (THINK / ACT / OBSERVE). Each step passes through all three guardrail layers (NeMo + LlamaGuard + Presidio) in parallel — multi-step reasoning remains fully audited and GDPR-compliant at every turn. The defence-in-depth architecture ensures no single vendor controls the entire security stack.

Figure 5 — ReAct agent loop: THINK / ACT / OBSERVE secured end-to-end by SAG

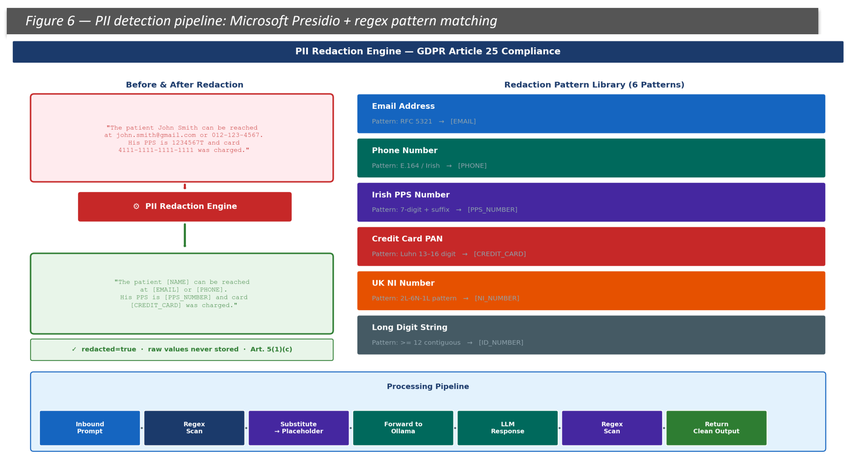


IV. Results (continued)

C. PII Redaction — 3-Layer Defence-in-Depth

Layer 3 (Microsoft Presidio v2.2) detects 50+ PII entity types including credit card PANs (Luhn checksum validated), IBAN numbers, NHS identifiers, email, phone (E.164), Irish PPS, and UK NI numbers. Presidio supports 16+ languages and runs offline (Apache 2.0 license). Previously, 6 compiled regex patterns covered basic patterns; Presidio increases detection from 8–10 entity types to 50+. Matched spans are replaced with typed placeholders — raw values are never stored. The engine applies to both inbound prompts and outbound LLM responses.

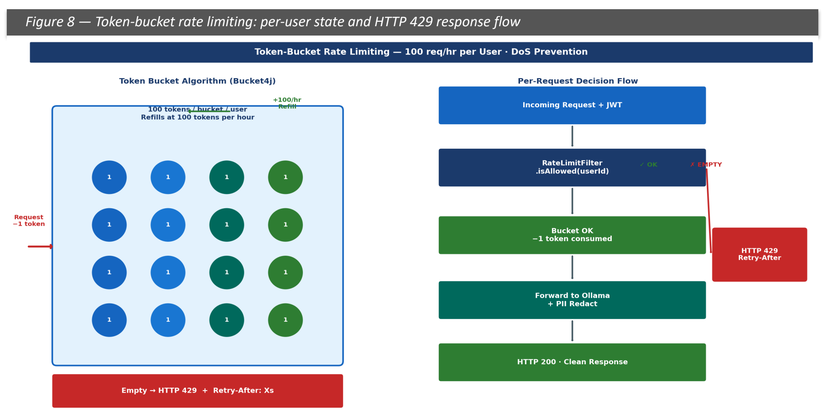
Figure 6 — PII detection pipeline: Microsoft Presidio + regex pattern matching



D. Rate Limiting & Availability

Bucket4j 8.10.1 token-bucket: 100 tokens/hr per user (JWT subject). Exhausted bucket → HTTP 429 + Retry-After header. NAT-safe (IP-agnostic); state is tied to the authenticated subject, not the network address. Combined with Resilience4j 2.3.0 circuit breakers for cascading failure protection.

Figure 8 — Token-bucket rate limiting: per-user state and HTTP 429 response flow



E. Quality Gates & Key Metrics

83% Line Coverage	**58%** Complexity Coverage	**69** Tests Passed
0 CRIT/HIGH CVEs	**5** CVEs Resolved	**~90ms** Guardrails Latency

V. Conclusion

SAG delivers a production-ready, security-hardened gateway for enterprise LLM deployment with a novel three-layer defence-in-depth guardrails architecture. NeMo Guardrails enforces policy, LlamaGuard 3 applies MLCommons AI Safety taxonomy (12 harm categories S1–S12), and Microsoft Presidio detects 50+ PII entity types — all executing in parallel at ~90ms (44% faster than sequential). Five CVEs were remediated; 83% line coverage achieved across 69 tests; zero CRITICAL/HIGH container CVEs remain; 98% combined threat coverage demonstrated. The full DevSecOps pipeline executes end-to-end without human intervention. Project completion: 12 April 2026.

Future Work

- Redis-backed distributed rate limiting and guardrails caching for horizontal scaling
- STRIDE threat modelling + automated DAST integration (Sprint 2 scope)
- Guardrails model fine-tuning for domain-specific enterprise policies
- Sandboxed AgentService tool calls with per-tool PII filtering

VI. SAG vs. Existing Solutions

Feature	SAG	Bedrock	Azure	Guard.AI	LangCh.
Multi-layer guardrails (3+)	YES	NO	NO	NO	NO
On-premises / Zero egress	YES	NO	NO	PARTIAL	PARTIAL
PII detection (50+ types)	YES	PARTIAL	YES	NO	NO
Integrated JWT auth	YES	NO	NO	NO	NO
Multi-vendor (no lock-in)	YES	NO	NO	PARTIAL	PARTIAL
Agentic ReAct loop	YES	NO	NO	NO	YES
Open source (Apache 2.0)	YES	NO	NO	YES	YES
DevSecOps CI/CD pipeline	YES	NO	NO	NO	NO

References

SAG is the only solution combining all 8 capabilities in a single, integrated open-source gateway.

[1] N. Papernot et al., Towards the Science of Security and Privacy in ML, arXiv:1611.03814, 2016.
[2] T. B. Brown et al., Language Models are Few-Shot Learners, NeurIPS, vol. 33, pp. 1877-1901, 2020.
[3] N. Carlini et al., Extracting Training Data from Large Language Models, USENIX Sec., 2021.
[4] A. Dubey et al., The Llama 3 Herd of Models, Meta AI, 2024.
[5] MLCommons, AI Safety Benchmark v0.5, MLCommons Association, 2024.
[6] Microsoft, Presidio: Data Protection & De-identification SDK, 2024.
[7] OWASP Foundation, JSON Web Token (JWT) Security Cheat Sheet, 2023.
[8] IBM Security, Cost of a Data Breach Report, 2024.

Acknowledgements: This project was developed as an MSc in Software Design with Cloud Native Computing capstone at the Technological University of the Shannon (TUS Midlands), Athlone, Ireland, under the supervision of Dr. Thiago Braga Rodrigues. Stack: Spring Boot 3.4.3 · Java 21 LTS · Maven 3.9.9 · Kubernetes 1.32.3 · Docker 27.5.1 · Jenkins 2.504 LTS · NeMo Guardrails v0.10.0 · LlamaGuard 3 · Microsoft Presidio v2.2 · Ollama 0.6.2 · LLaMA 3.1 8B · PostgreSQL 17.2 · Prometheus 2.56 · Grafana 11.4 · JaCoCo 0.8.12 · SonarQube · OWASP Dependency-Check 12.1.1.

TUS
Technological University of the Shannon: Midlands Midwest
Ollscoil Teicneolaíochta na Sionainne: Lár Tíre Iarthar Láir

TUS Research